

Exam Date & Time: 15-Nov-2025 (09:30 AM - 12:30 PM)



MANIPAL ACADEMY OF HIGHER EDUCATION

MANIPAL INSTITUTE OF TECHNOLOGY - BENGALURU
SEVENTH SEMESTER B.TECH. DEGREE EXAMINATIONS - NOVEMBER 2025

Systems and Network Security [CSE_5117]

Marks: 50

Duration: 180 mins.

PART-A

Answer all the questions.

- 1) A fintech startup uses AI models trained on customer data. During an audit, it was found that while data confidentiality was intact, the models produced misleading outputs due to corrupted training files.
 - A) a) Apply the Parkerian Hexad to identify which additional principles are violated in this situation and justify your answer. (5)
b) Recommend the corrective actions or controls to restore the violated principles.
 - B) A university's cloud-based student information portal has recently faced several unusual events: The system performance has slowed down, and logs show a large volume of network requests directed toward the gateway from multiple locations.
 - Several IT staff members report receiving emails asking them to "verify account details" and click on embedded links.
 - During a recent security audit, it was discovered that all administrative accounts share a single password and that sensitive data in the cloud is stored without encryption.

The university's risk assessment committee wants to evaluate the overall security exposure using the relation: (5)

$$\text{Risk} = \text{Probability} (\text{Threat} \times \text{Exploit of Vulnerability}) \times \text{Cost of Asset Damage}$$
 - a) Examine and classify the key assets, vulnerabilities, and risk factors evident in this scenario, and briefly explain how each contributes to overall risk.
 - b) Infer one risk mitigation and one risk transfer strategy suitable for the university's situation.
 - c) Analyze based on the observed system behavior and staff incidents, infer the possible categories of threats involved, and recommend administrative or technical control that could address them.
- 2) A research university noticed unusual spikes in outbound network traffic during off-hours, but firewall logs show no known malware or external breach signatures. At the same time, several laboratory computers exhibit unauthorized file access attempts and encrypted connections to unfamiliar destinations. Due to budget constraints, the IT team can initially deploy only one type of IDS and must later justify whether a hybrid model is necessary. (5)
 - A) a) Analyze the situation to determine whether a Network-based IDS (NIDS) or a Host-

based IDS (HIDS) would provide more effective initial visibility. Justify your choice with respect to the type of evidence available and monitoring scope.

b) Design a hybrid intrusion detection strategy that combines the strengths of both models to detect and respond to multi-vector insider and external threats.

c) If the university later integrates machine-learning-based anomaly detection into this setup, explain one potential advantage and one challenge it may introduce.

B) A technology firm is designing a new secure operating system for global deployment. The architects propose using a microkernel architecture with strong compartmentalization to reduce attack surface. However, network engineers warn that the OS will still rely on TCP/IP Version 4, which lacks built-in security features. Management wants a comprehensive explanation of how the Operating System Security Model (TCB) can ensure trust when the underlying communication protocols remain insecure.

a) Demonstrate how the Trusted Computing Base (TCB) defines the operating system security model and supports layered protection within the host. (5)

b) Using the Titanic Analogy, analyze how poor compartmentalization or untested module boundaries can undermine an otherwise secure OS design.

c) Evaluate why relying on insecure network protocols such as TCP/IP Version 4 weakens overall system assurance and how protocol-level improvements strengthen the end-to-end security model.

3) A fintech company processes sensitive financial data using a distributed, cloud-based system. Regulatory auditors require that the system's design follows recognized security models to ensure confidentiality, integrity, and accountability, and that it can be evaluated using the Trusted Computer System Evaluation Criteria (TCSEC) framework.

A) a) Examine which of the classic security models that best suit such a financial application, and justify your choice. (5)

b) Infer how these models can be applied or adapted together to maintain confidentiality, integrity, and accountability in modern distributed systems, such as cloud-based financial platforms.

c) Using the TCSEC framework, identify which evaluation class would be most suitable for such a system and justify your selection.

B) A company launches a new e-commerce site and configures its firewall on a "allow-everything-not-specifically-denied" policy to avoid blocking legitimate customer traffic. A month later, the site experiences data exfiltration and malware callbacks. (5)

a) Analyze how this policy choice contributed to the breach.

b) Outline a revised policy model and justify how it balances usability and security.

4) A research university plans to introduce a Demilitarized Zone (DMZ) to host its public web and email servers while keeping internal academic systems isolated. However, the network team is concerned that adding a DMZ may complicate performance, routing, and management.

A) a) Analyze how introducing a DMZ improves network segmentation and reduces exposure of internal assets compared to a flat network design. (5)

b) Discuss potential challenges of maintaining a DMZ, and suggest ways to overcome them without weakening security.

c) Infer how the DMZ contributes to the organization's overall layered security and defense-in-depth strategy.

- B) A multinational organization uses Kerberos for authentication across different country-based domains (realms). Employees can log in successfully within their own region but face denial when accessing resources hosted in another realm.
 a) Assess how Realms and Inter-Realm Authentication function in Kerberos. (5)
 b) Demonstrate how trust relationships between realms are established and maintained.
 c) Interpret the security risk if the inter-realm ticket exchange is misconfigured, and suggest a mitigation measure.
- 5) A journalist sends confidential emails using Pretty Good Privacy (PGP) encryption. However, recipients sometimes receive messages marked "signature verification failed."
 A) a) Analyse how PGP's hybrid cryptosystem (symmetric + asymmetric encryption) ensures both confidentiality and authenticity. (5)
 b) Analyse how key rings (public and private) manage user identity and enable verification of digital signatures.
 c) Evaluate two possible causes for the "signature verification failed" anomaly in this case.
- B) A security administrator reports that VPN connections occasionally fail when rekeying occurs during heavy traffic. Packet traces show incomplete Quick Mode exchanges.
 a) Demonstrate the 3-message exchange process of IKE Quick Mode and its purpose in IPSec SA negotiation.
 b) Assess how nonces, Diffie-Hellman values, and Perfect Forward Secrecy (PFS) strengthen Quick Mode security. (5)
 c) Suggest two best practices for maintaining Quick Mode stability and reducing rekeying disruptions.

-----End-----

Event Name	Subject
058-END SEMSTER-ODD-2025	CSE_5117:Systems and Network Security

#	Course Outcome	Description	Marks
1	1	CO 1	5
2	2	CO 2	5
3	3	CO 3	15
4	4	CO 4	10
5	5	CO 5	15
Total			50

* NA - CO Not Selected

Event Name	Subject
058-END SEMSTER-ODD-2025	CSE_5117:Systems and Network Security

#	Level	No of Questions	Marks (%)
---	-------	-----------------	-----------

1	Remember	0	0(0%)
2	Understand	0	0(0%)
3	Application	4	20(40%)
4	Analysis	6	30(60%)
5	Create	0	0(0%)
6	Evaluate	0	0(0%)
Total		10	50 (100%)